EWB Courses - AI-Powered Cybersecurity

Assessment 01: Security Foundations

Name: Jythraa **Batch/Group:** Not assigned

Submitted for: Assessment issued 18 October 2026 (individual work, 100 marks)

Task A: Secure a student account

A1 and A2: Risks, assets, CIA impact, controls and limitations

Risk	Asset	CIA impact	Control	Limitation
1. Same short password used for email and learning portal	Email and learning portal accounts	**Confidentiality:** if the password is cracked, the person can read Mira's details. **Availability:** they could change the password and lock her out of both accounts.	Use a unique, long passphrase for each account, stored in a password manager. One stolen password no longer opens her other accounts.	If the password manager's master password is weak, all the passwords can be stolen.
2. Approving unexpected sign-in prompts	Email and portal accounts	**Confidentiality:** an unexpected prompt usually means someone else already has her password, so approving lets them in. **Integrity:** they could change data or transfer files.	Deny any prompt she did not start and change her password. Denying stops this attempt, and the new password cuts off the attacker's stolen copy.	Attackers can keep sending prompts until she approves one.
3. Postponing device updates	Laptop operating system	**Confidentiality, Integrity, Availability:** unpatched weaknesses stay open, so attackers can access data, modify it or lock her out.	Turn on automatic system updates. This closes known security holes.	Updates cannot fix flaws that nobody has discovered yet.
4. Only one copy of the project	Project files	**Availability:** if the laptop fails or the files are lost or deleted, there is no other copy.	Keep multiple copies on different devices such as a hard disk and a pen drive. If one copy is lost, another is available.	A USB drive can carry malware back to the laptop.
5. A friend uses the laptop under Mira's signed-in account	The signed-in account and the files in it	**Confidentiality:** files may be viewed. **Integrity:** data may be modified. **Availability:** files may be deleted.	Sign out and lock the account, and create a guest account for the friend. This keeps her account and files safe.	Only works if Mira remembers to lock every time, and does not help if the friend already knows her password.

A2 (continued): Priorities

1. **First: unique long passphrase in a password manager (risk 1).** One weak password opens both accounts, so it is the easiest way in.
2. **Second: deny prompts she did not start (risk 2).** MFA is her safety net. If she approves by habit, even a stolen password gets the attacker in.
3. **Third: separate guest account and screen lock (risk 5).** A friend already has physical access and a signed-in session, so no hacking is needed.

Updates and backups come after these. They reduce damage from rarer events, while the first three give an attacker or another person direct access today.

A3: Authentication versus authorisation

Authentication proves who you are. When Mira uses her email and password to enter the learning portal, that is authentication. To view her personal details the portal may also ask for a one-time password (two-factor verification).

Authorisation decides what a verified person is allowed to do. Mira can view her own grades but cannot modify other students' grades. In a typical portal, submission also closes at the deadline, and only the learning portal coordinator can reopen it for her.

If Mira's friend uses her signed-in account, the portal still sees her as Mira and gives full permissions. This ties back to risk 5.

Task B: Analyse a suspicious message

B1: Five warning signs

Phrase	Why it needs scrutiny
"awards@campus-awards.example" / "help@personal-awards.example"	The reply-to differs from the sender, and neither matches the college's usual domain, campus.example.
"FINAL WARNING - scholarship expires in 20 minutes"	Time pressure is meant to make the student panic and click without checking.
"enter your college password and OTP"	Colleges do not normally ask for these through a link.
"Do not contact the college office"	This stops you from verifying the source, which is why it is the biggest flag.
"Reply with a photo of your identity card"	The college already has the student's details because it issued the card. An ID photo can be used for identity theft.

B2: Safe verification

1. Do not reply to the message or click any links.
2. Find the official contact yourself, for example by typing the college portal address or using the contact details on the college website.
3. Ask the college office whether this scholarship exists, and trust their answer, not the message.

Why HTTPS does not prove the message is genuine: HTTPS only encrypts the connection to whoever runs the site, so a scammer's site can have it too. It does not show who that is.

Why a display name does not prove it: the display name is set by the sender, so "Scholarship Desk" is just text anyone can type. The real sender address is what to check.

B3: Response plan if the password and OTP were already entered

1. **Containment:** change the password and sign out of all active sessions from another safe device, using the official portal address you typed yourself.
2. **Official reporting:** inform the college IT helpdesk using contact details from the college's official website, not from the message, and send the phishing message as evidence if asked.
3. **Follow-up checks:** review recent sign-in activity for unknown devices or locations, and change the password on any other account that uses the same password.

B4: What cannot be established

I cannot establish who really sent this message from the text alone. The full email headers would help because they show the route it took, and confirmation from the college scholarship office would show whether the award exists.

Task C: Triage a sign-in alert

C1: Timeline (observed events, then interpretation)

1. **09:00-09:01:** password and MFA succeed from 192.0.2.10 (the usual classroom IP).
2. **10:14-10:16:** two failed passwords, then a success, from 198.51.100.23.
3. **10:17-10:18:** MFA denied, then approved. *Student states* they approved at 10:18 to stop the repeated requests.
4. **10:20:** session created from 198.51.100.23. *Student states* they did not sign in after 09:05.

Interpretation (not observed): since the student states they did not sign in after 09:05, the pattern fits someone else using the password and the student approving the prompt to stop the requests, known as MFA fatigue.

C2: Likely and alternative explanations

Likely: a person other than the student entered the correct password after two failed attempts and sent repeated MFA prompts until one was approved, which is consistent with MFA fatigue.

Alternative: the student or someone they know signed in from a different device or network and has forgotten, or approved the prompts without realising.

Two checks that could distinguish them:

1. Do the device and browser recorded for the 10:20 session match the student's usual ones?
2. Is 198.51.100.23 a known network, such as the college Wi-Fi or the student's own mobile data? The IT team can check this.

An IP address shows where a connection came from, not who was using it.

C3: Prioritised response actions for the authorised IT team

1. **Protect the account:** revoke all active sessions, including the one created at 10:20, reset the password and ask for MFA sign-in again. Take a copy of the logs first so nothing gets overwritten.
2. **Preserve evidence:** save the sign-in logs, MFA prompt records and session details without deleting them, so it can be confirmed what happened.
3. **Review and follow up:** check what the 10:20 session accessed, check if 198.51.100.23 appears on other accounts, and tell the student to deny any prompt they did not start.

C4: Incident summary

student07 signed in at 09:00 from the usual classroom IP, 192.0.2.10. From 10:14 to 10:16, two passwords failed and then one succeeded from 198.51.100.23, followed by MFA denied, then approved, and a session at 10:20. The student states they did not sign in after 09:05 and approved a prompt to stop the requests. The pattern fits MFA fatigue, but the IP does not identify who it was, so it is uncertain. Priority is high because the session may still be open. Next action: IT should revoke sessions, reset the password and preserve the logs.

Task D: Review an AI security answer

D1: Five unsafe or unsupported claims, corrected

Claim or action in the AI output	Correction and evidence
"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection. It does not show who runs the site or whether the message is genuine. The message in Task B has a domain mismatch, urgency and requests for a password and OTP, so it is suspicious (CISA phishing guidance).
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	The log shows events from an IP address, not who was using it. It also does not show how the password was obtained. Task C gives an alternative explanation, so the claim is unsupported.
"MFA prevents every account compromise."	MFA greatly reduces risk but not every compromise. In Task C the student approved a prompt to stop repeated requests (MFA fatigue), and a session was created.
"Delete the suspicious logs."	Logs are evidence. Deleting them destroys the record needed to confirm what happened. They should be preserved and given to the authorised IT team.
"Send the student's password to support so they can test it."	Passwords and OTPs must never be shared, even with support. Testing a password is not needed. The student should change the password through the official portal and report the incident.

The NIST AI 600-1 profile notes that AI can state wrong information with confidence (confabulation), which is why each claim above was checked against the evidence.

D2: A better prompt

"Analyse only the evidence I paste below, which consists of a sign-in log and a sample message. Do not ask for, accept or repeat any real passwords, OTPs or personal data. (1) List observed facts separately from assumptions. (2) Give one likely and one alternative explanation. (3) State what cannot be concluded from this evidence and what extra evidence would help. (4) Suggest prioritised, safe actions for an authorised IT team. (5) State your uncertainty and flag anything that needs human verification. [paste synthetic evidence here]"

D3: Corrected security advice

A message is not safe just because it uses HTTPS. HTTPS only encrypts the connection and does not show who runs the site, so verify through the official college portal or contact details you found yourself. As in my Task C answer, the logs show a successful login from 198.51.100.23, but an IP address shows where a connection came from, not who was using it, so the logs do not prove who stole the password. MFA reduces risk but does not stop every compromise, because the student in Task C approved a prompt to stop the requests (MFA fatigue). Never delete logs; preserve them for the IT team. Never send a password or OTP to anyone, including support. Change the password from a safe device and report the incident through official channels.

D4: AI-use declaration and evidence notes

AI-use declaration: I used Claude (Anthropic) for concept exploration and for cross-verifying my answers against the class notes and the websites listed in the assessment. I wrote Tasks A, B, C1 and C2 myself. For Task C3, Task C4 and Task D, Claude gave draft suggestions, which I reviewed and reworded in my own style. Claude also helped format this report.

1. CISA, Secure Our World: guidance on strong unique passwords, MFA, software updates, backups and spotting phishing. It supports the controls in Task A, the verification steps in Task B and the correction on HTTPS and MFA in Task D.
2. NIST AI 600-1, Generative AI Profile: describes confabulation (confident but wrong AI output) and the need to verify AI answers. It supports the review of the AI output in Task D.

References

CISA - Secure Our World: https://www.cisa.gov/secure-our-world
NIST - Generative AI Profile, AI 600-1: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf